

Challenge-SOC

Triage, Afinado y Detección de Alertas SOC

Sos analista del SOC de "Acme Fintech" (empresa que opera sobre GCP). Tu turno se basa en sostener la cola de alertas. Triagear con criterio y velocidad, afinar las reglas que generan ruido, proponer una regla nueva donde falta cobertura, e integrar la herramienta de apoyo que uses todos los días.

Se entrega junto con este challenge:

- **alertas_dataset.json** — alertas ya generadas por el SIEM (formato similar a Splunk Notable Events / Sentinel Incidents). Mezclan true positives, false positives y "benignos pero mal configurados".
- **logs_soporte.zip** — logs crudos de auth, VPC flow y EDR, para resolver las alertas que lo requieran.
- **reglas_actuales.md** — lógica simplificada de las reglas del SIEM que generaron las alertas de este dataset. Es necesaria para proponer un ajuste concreto, no a ciegas.

Qué se espera

- Desarrollar los entregables usando el formato que corresponda a cada uno: el script de apoyo en Python 3.11+ (o Bash), y el resto de los entregables (triage, ajustes de reglas, regla nueva, correlación) en Markdown o CSV.
- Triage del lote de alertas (triage.csv): clasificación, severidad, justificación breve (2 a 3 líneas por alerta, no un ensayo), y acción: *Cerrar / Afinar regla / Escalar*.
- Afinado de reglas ruidosas (ajuste_reglas.md): para las alertas que se clasifiquen como falso positivo o benigno mal configurado, proponer la condición de exclusión en SQL o pseudo-código sobre la regla actual (ver reglas_actuales.md), y responder: ¿qué falso negativo se podría estar introduciendo si esa excepción queda demasiado amplia?
- Una regla nueva (regla_nueva.md): en los logs de soporte hay al menos un patrón de actividad que no generó ninguna alerta dedicada. Encontrarlo y escribir, en SQL o pseudo-código, la lógica de una regla que lo hubiera detectado, con el umbral elegido y por qué no dispara con actividad legítima.
- Nota de correlación (correlacion.md, media página máximo): si dos o más alertas comparten entidad (usuario/host/IP) en una ventana de tiempo continua, indicar si están relacionadas y qué acción se tomaría. No se pide timeline exhaustivo ni reconstrucción forense completa, se pide el criterio para decidir si esto queda en SOC o sube a Tier 2/IR.

- Script de apoyo: búsqueda de IOC y/o resumen de alertas, ejecutable por CLI con manejo básico de errores.
- Métricas del turno (*metricas_turno.md*): tiempo aproximado que tomó triagear el lote, % de falsos positivos por regla, y cuántas alertas quedaron pendientes de validar contra el inventario de activos.

Bonus

- Mapeo a MITRE ATT&CK (alcanza con la técnica por alerta, no un documento dedicado extenso).
- Whitelist configurable de IPs/dominios confiables, con justificación, owner y fecha de revisión.
- Reporte de escalamiento corto (una página) solo para las alertas que se decida escalar.

Extra Bonus

- Notificación por webhook de las alertas escaladas.
- *resumen_turno.md* tipo shift handover.

Entregables

Estructura de carpetas + README con instrucciones, criterios usados y documentación adicional. Subir el resultado a un repositorio de GitHub, con commits incrementales a medida que se avanza (no un solo commit final), y compartir el link del repositorio.

Cómo se evalúa

- Criterio y velocidad de triage a volumen, con más peso que la profundidad en un solo caso.
- Calidad del pseudo-código de las reglas (afinado y nueva): que sea ejecutable en su lógica, no solo descriptivo.
- Que se reconozca el trade-off de falsos negativos al proponer una exclusión.
- Que la nota de correlación identifique la cadena real sin necesidad de un informe forense completo.
- Que el script funcione con los archivos tal como se entregan, sin pasos manuales adicionales.

Tiempo estimado

4 a 6 horas.